PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Cybersécurité des systèmes industriels et classification

03-990 ANSSI - Cybersécurité des systèmes industriels, méthode de classification et mesures détaillées — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La classification repose sur 4 classes fondées uniquement sur l'impact pour assurer la stabilité du système.
2. Le surclassement permet d'attribuer une classe supérieure à une zone en cas de sites répartis ou de zones impossibles à cloisonner.
3. En classe 4, la télémaintenance est proscrite et les flux vers la gestion doivent passer par une diode.

Synthèse des enjeux de cybersécurité industrielle

Notion	À retenir
Des systèmes à part	L'**OT** utilise l'**IT** sans conception sécurisée initiale. Les vulnérabilités sont nombreuses, notamment dans les **piles protocolaires des automates**.
Les idées reçues	L'**isolement est un mythe** (connexions, clés USB, maintenance). Les **protocoles propriétaires** ne protègent pas. La **sécurité** et la **sûreté** se rejoignent.
Approche globale IT/OT	Nécessite une **volonté à tous les niveaux** et l'intégration de la sécurité dans les projets dès leur **conception**.

Les quatre classes de cybersécurité

Notion	À retenir
Définition	Classe **1** (impact **faible**), **2** (impact **modéré**, preuve de mesures requise), **3** (impact **fort**, mesures renforcées, vérification recommandée), **4** (impact **catastrophique**, mesures les plus fortes, vérification recommandée).
Méthode d'impact	Version **2** : **4 classes** fondées sur la seule **criticité des impacts**, classe stable. La version **1.0** (3 classes, impact + vraisemblance) aboutissait souvent à la classe 3 avec un effet de bouclage. Pas d'équivalence avec les **SL de l'IEC 62443** (niveau de menace).
Échelles de gravité	Impacts humains : **1 mineur** (arrêt/traitement), **2 modéré** (invalidité permanente), **3 majeur** (décès), **4 catastrophique** (plusieurs décès). Autres : environnement, collectivité, économique (optionnelle).

Objectifs des classes

Classes	Objectif
1 et 2	**Résilience** : surmonter une panne ou une attaque et redémarrer
3 et 4	**Survivre** à une attaque

Méthode de classification

Notion	À retenir
Activités EBIOS RM	1 : définir **cadre**, **objectifs**, **hypothèses**, **périmètres** ; 2 : établir des **zones** ; 3 : identifier **événements redoutés** et déduire la **classe**.
Surclassement	Sites répartis surclassés si un **événement simultané** a un impact significatif ; zones non cloisonnables (SIS et automate standard) surclassées vers la **classe la plus élevée**. **Dépendance fonctionnelle** : zone ayant besoin d'une donnée d'une autre ; même classe = risque acceptable, sinon interconnexion sécurisée. IEC 62443 : un **conduit** hérite du niveau le plus élevé.
Lien EBIOS RM	Les mesures du **guide de mesures détaillées** alimentent le **socle de sécurité** d'une analyse EBIOS Risk Manager une fois les classes déterminées.

Synthèse des mesures détaillées

Notion	À retenir
Organisation du guide	Version **2 de décembre 2025** ; recommandations de **C1 à C4** ; le verbe **devoir** est plus prescriptif que **il est recommandé**.
Mesures organisationnelles	Connaître le système, maîtriser les intervenants, intégrer la cybersécurité au **cycle de vie**, assurer la **sécurité physique** et le **contrôle d'accès** aux locaux, anticiper/réagir aux incidents.
Mesures techniques	Authentification et **contrôle d'accès logique**, sécurisation de l'**architecture**, sécurisation des **équipements** et **supervision de sécurité**.
Interconnexions et télémaintenance	Classe 1 : **pare-feu** aux passerelles, télémaintenance sécurisée. Dès la classe 2 : **flux unidirectionnels** recommandés. Dès la classe 3 : **sondes de détection**. Classe 4 : télémaintenance **proscrite** ; si impérative, équipements distants et liaison intégrés au périmètre C4.

Secteur de la chimie (ANSSI et France Chimie, 2026)

Point	À retenir
Sources de risque	**Étatiques**, **cybercriminelles**, **internes** ; objectifs lucratifs, déstabilisation, espionnage
Cibles et vecteurs	Données de **R&D** ; **rançongiciel** par la porosité gestion/industriel ; **chaîne d'approvisionnement** (compromission d'un éditeur)
Chiffre	En 2024, **37 %** des victimes de rançongiciels signalées à l'ANSSI : TPE, PME ou ETI

Pièges et confusions

- ⚠ Confondre les classes de cybersécurité avec les niveaux de sécurité (SL) de l'IEC 62443
- ⚠ Croire que la classification actuelle combine l'impact et la vraisemblance comme la version 1.0
- ⚠ Penser qu'un réseau industriel isolé est protégé contre les clés USB et les consoles de maintenance
- ⚠ Oublier qu'une modification du système industriel impose de réexaminer sa classe

Sigles et définitions

OT	technologie opérationnelle pour conduire et surveiller des procédés ayant une action physique directe
IT	technologie de l'information désignant l'informatique de gestion
Zone	partie du périmètre industriel regroupant des équipements de même criticité
Passerelle unidirectionnelle	équipement appelé diode qui ne laisse passer les données que dans un seul sens
SdF	sûreté de fonctionnement visant la fiabilité et la sécurité des installations face aux défaillances
SIS	système instrumenté de sécurité comme un automate de sécurité fonctionnelle

Auto-test

1. Combien de classes de cybersécurité existent dans la classification actuelle ?
2. Quel est l'objectif des classes 1 et 2 ?
3. Quelle méthode est utilisée pour l'analyse des modes de défaillance et de leurs effets ?
4. Qu'est-ce que la dépendance fonctionnelle ?
5. Quelle est la norme internationale de cybersécurité des systèmes d'automatisation industrielle ?

Réponses : **1.** 4 · **2.** Mettre l'accent sur la résilience · **3.** AMDEC · **4.** Lorsqu'une zone a besoin d'une donnée provenant d'une autre zone pour réaliser une fonction · **5.** IEC 62443

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.